

Vulnerability Assessment and Exploit Research

Ethical Hacking Lab 3 - Operation Black Hat

Raliegth Barnett | Cybersecurity & Networking Portfolio

Portfolio Case Study - Detailed Project Oversight and Completion Record

All offensive-security activities described in this document were performed in authorized, isolated academic laboratory environments.

1. Project Overview

A vulnerability-management project that correlated exposed service versions with published weaknesses and verified findings through Nmap NSE, Searchsploit/Exploit-DB research, OpenVAS, Nikto, and a custom Bash automation workflow.

Project Field	Details
Role and Responsibility	Vulnerability assessor, exploit researcher, automation author, and report writer.
Environment and Tools	Kali Linux, Metasploitable 2, Nmap NSE, Searchsploit, OpenVAS/Greenbone, Nikto, Bash.
Completion Status	Completed - documented, tested, and included in the master portfolio.
Portfolio Classification	Academic / personal technical project with recruiter-facing case-study documentation.

2. Project Objectives and Success Criteria

- Build a service/version inventory.
- Identify and validate high-risk weaknesses.
- Map findings to CVEs and platform-appropriate exploit references.
- Compare manual and automated vulnerability assessment.
- Automate service-banner to Searchsploit lookup.

3. Project Oversight and Execution Process

3.1 Planning and Scope

Defined the authorized environment, project goal, tools, expected outputs, and safety limitations.

3.2 Implementation

Executed the technical tasks and maintained notes, commands, screenshots, and configuration evidence.

3.3 Validation and Testing

Compared actual output with objectives, confirmed repeatable behavior, and collected proof of completion.

3.4 Analysis and Reporting

Converted technical evidence into findings, defensive interpretation, limitations, and recommendations.

3.5 Portfolio Finalization

Prepared a recruiter-friendly summary, detailed case study, screenshots, source report, and public-release guidance.

4. Technical Methodology

1. Performed Nmap service/version, default-script, and OS detection.
2. Prioritized high-value services and used targeted NSE vulnerability checks.
3. Researched exploit references with Searchsploit and filtered platform mismatches.
4. Created a Bash script that extracts Nmap banners and searches the offline exploit database.
5. Used OpenVAS and Nikto for broader vulnerability and web-server assessment.
6. Converted findings into remediation priorities.

5. Deliverables and Completion Evidence

Deliverable	Status	Evidence
Technical implementation / lab execution	Complete	Commands, configurations, code, or forensic workflow documented.
Testing and validation	Complete	Results and screenshots included below and in the original report.
Detailed project documentation	Complete	This case-study document and README.
Source/original evidence	Complete	Original report or source files stored in this project folder.
Recruiter-ready description	Complete	Summary and skills section included.
Public publishing review	Required before posting	Remove credentials, personal identifiers, confidential case data, and unnecessary target details.

6. Results and Outcomes

- The assessment confirmed multiple critical legacy vulnerabilities and showed why version evidence must be behaviorally validated.
- Manual research provided context while automated scanners broadened coverage.
- The Bash workflow made exploit research faster and repeatable.

7. Challenges, Decisions, and Lessons Learned

- Separating confirmed vulnerabilities from version-based possibilities.
- Avoiding duplicate or irrelevant exploit matches.

8. Screenshots and Supporting Evidence

Port	Service	Version
21/tcp	FTP	vsftpd 2.3.4 (backdoored)
22/tcp	SSH	OpenSSH 4.7p1 Debian 8ubuntu1
23/tcp	Telnet	Linux telnetd
25/tcp	SMTP	Postfix smtpd
53/tcp	DNS	ISC BIND 9.4.2
80/tcp	HTTP	Apache httpd 2.2.8 (Ubuntu) PHP/5.2.4
111/tcp	RPC	rpcbind 2 (RPC #100000)
139/tcp	NetBIOS-SSN	Samba smbd 3.x workgroup WORKGROUP
445/tcp	SMB (Microsoft-DS)	Samba 3.0.20-Debian
512/513/514	r-services	rexecd / rlogind / rshd
1524/tcp	Bindshell	Metasploitable root shell
2049/tcp	NFS	nfs 2-4 (RPC #100003)
3306/tcp	MySQL	MySQL 5.0.51a-3ubuntu5
3632/tcp	distccd	distccd v1 (GNU) 4.2.4
5432/tcp	PostgreSQL	PostgreSQL DB 8.3.0 – 8.3.7
5900/tcp	VNC	VNC protocol 3.3
6000/tcp	X11	access denied
6667/tcp	IRC	UnrealIRCd 3.2.8.1 (backdoored)
8009/tcp	AJP13	Apache Jserv 1.3
8180/tcp	HTTP (Tomcat)	Apache Tomcat/Coyote JSP 1.1

Ports that stand out as high-value targets:

- 21/tcp – vsftpd 2.3.4 (known backdoor, CVE-2011-2523).
- 445/tcp – Samba 3.0.20 (CVE-2007-2447 usermap_script RCE).
- 6667/tcp – UnrealIRCd 3.2.8.1 (CVE-2010-2075 backdoor).
- 512-514/tcp – r-services (accept connections from any host with trust file).
- 3632/tcp – distccd (CVE-2004-2687 arbitrary command execution).
- 5432/tcp – PostgreSQL 8.3 (default weak credentials).
- 8180/tcp – Tomcat with default tomcat/tomcat admin credentials.

Q: Do you trust what you see?

Service inventory and high-value vulnerability targets.

```
#!/bin/bash
# auto_searchsploit.sh – feed Nmap output into Searchsploit
# Usage: ./auto_searchsploit.sh <target-ip>

TARGET="${1:-192.168.56.101}"
OUT="nmap_${TARGET}.txt"

echo "[*] Running service-version scan on $TARGET ..."
sudo nmap -sV -Pn -T4 -oN "$OUT" "$TARGET" >/dev/null

echo "[*] Extracting service banners ..."
# Lines look like: 21/tcp open  ftp  vsftpd 2.3.4
SERVICES=$(awk '/^[0-9]+\V/tcp/ && /open/ {
    $1=""; $2=""; $3="";
    sub(/^\+/, "");
    if (length($0) > 0) print $0
}' "$OUT" | sort -u)

echo "[*] Running searchsploit for each banner ..."
while IFS= read -r svc; do
    [ -z "$svc" ] && continue
    echo ""
    echo "=====
    echo "  SERVICE: $svc"
    echo "=====
    searchsploit --colour "$svc" | head -n 20
done <<< "$SERVICES"

echo ""
echo "[*] Done. Full Nmap output saved to $OUT"
```

Why this approach is efficient:

- Only one active Nmap scan is run; Searchsploit queries the offline Exploit-DB mirror (no internet calls), so results are instant.
- awk extracts the banner text directly from -oN output – no parsing libraries needed.
- Results are deduplicated with sort -u, preventing repeated queries for identical banners.
- Output is streamed per-service so the analyst can triage exploits as they appear instead of waiting for a full report.

Sample output (truncated):

```
=====
SERVICE: vsftpd 2.3.4
=====
Exploits:
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit) | linux/remote/17491.rb
```

Automated Nmap-to-Searchsploit workflow.

9. Skills Demonstrated

Vulnerability assessment, CVE mapping, Nmap NSE, Searchsploit, OpenVAS, Nikto, Bash automation, risk prioritization.

10. Recommendations and Future Improvements

- Use CVSS, asset criticality, and exploitability to produce a formal risk register.
- Add retesting evidence after remediation.

11. Portfolio and Resume Presentation

Vulnerability Assessment and Exploit Research - A vulnerability-management project that correlated exposed service versions with published weaknesses and verified findings through Nmap NSE, Searchsploit/Exploit-DB research, OpenVAS, Nikto, and a custom Bash automation workflow.

Recommended repository contents: README.md, Documentation/, Evidence/, Source/ or Original_Report/, and a clear authorization/privacy notice.

12. Completion Statement

This project is considered complete for portfolio use because the scope, implementation process, testing evidence, results, skills, limitations, and future improvements are documented. Before public release, sensitive data must be reviewed and removed.